SIMATS ENGINEERING
Saveetha Institute of Medical And Technical Sciences
ASSESSMENT TOOL 2

Social Engineering Simulation
Report Analysis

Name	B Akshaya
Register Number	192424336
Date	22.10.2026
Course Code	ITA1420
Course Name	Ethical Hacking

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30% | **Duration:** 90 min | **Total Marks:** 50

Code of Conduct:

I B Akshaya (192424336) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Akshaya

1. Introduction

1.1 Background

Social engineering attacks target people rather than machines. Before an attacker sends a single message, they perform **foot printing**: collecting public information about the organization, its domain, hosts, staff roles and technology. Open-Source Intelligence (OSINT) makes this possible without touching the target network, while active techniques such as port scanning add technical depth. This report applies Course Outcome CO2 by performing three foot printing and simulation tasks and analyzing how an attacker could turn the results into social engineering attacks.

1.2 Objectives and Scope

Table 1: Assessment tasks, tools and targets

Task	Activity	Tool	Target	Marks
Q1	OSINT e-mail, subdomain, host and IP enumeration	theHarvester	tesla.com	20
Q2	Phishing awareness simulation	GoPhish	Dummy lab accounts	20
Q3	Aggressive scan and attack-methodology analysis	Nmap (-A)	scanme.nmap.org	10

1.3 Lab Environment and Ethical Considerations

All work was performed from **Kali Linux**. For tesla.com only passive, publicly indexed sources were queried; no login, exploitation or intrusion was attempted. The GoPhish campaign used only the dummy employee accounts provided in the lab, and scanme.nmap.org is a host the Nmap project explicitly permits for scan practice. Attacker behaviour is described only to explain risk and to justify defences.

1.4 Methodology



Figure 1: Overall assessment methodology (Q1 to Q3)

1.5 Key Terms

Term	Meaning
Footprinting	Systematic collection of information about a target before an attack
OSINT	Intelligence gathered from public sources such as search engines, certificate logs and DNS
Spear-phishing	A targeted phishing message personalised to one person or role
Credential harvesting	Capturing usernames and passwords through a fake login page
Pretexting / Vishing	Inventing a believable story, often by phone, to obtain access or information

2. OSINT Data Collection and Analysis

2.1 Q1: E-mail and Host Enumeration with theHarvester

theHarvester queries public sources (certificate transparency logs, passive DNS and search engines) and returns e-mails, subdomains, hosts and IP addresses. The commands executed are listed below.

Table 2: Commands executed in Kali Linux

Step	Command	Purpose
1	theHarvester -d tesla.com -l 200 -b crtsh,hackertarget,rapiddns,duckduckgo -f tesla_osint	Collect e-mails, subdomains, hosts and IPs; export XML/JSON
2	dig +short www.tesla.com	Resolve a discovered host to its IP address
3	whois tesla.com	Registrar, name servers and contact metadata
4	host -t mx tesla.com	Identify the mail servers used by the domain

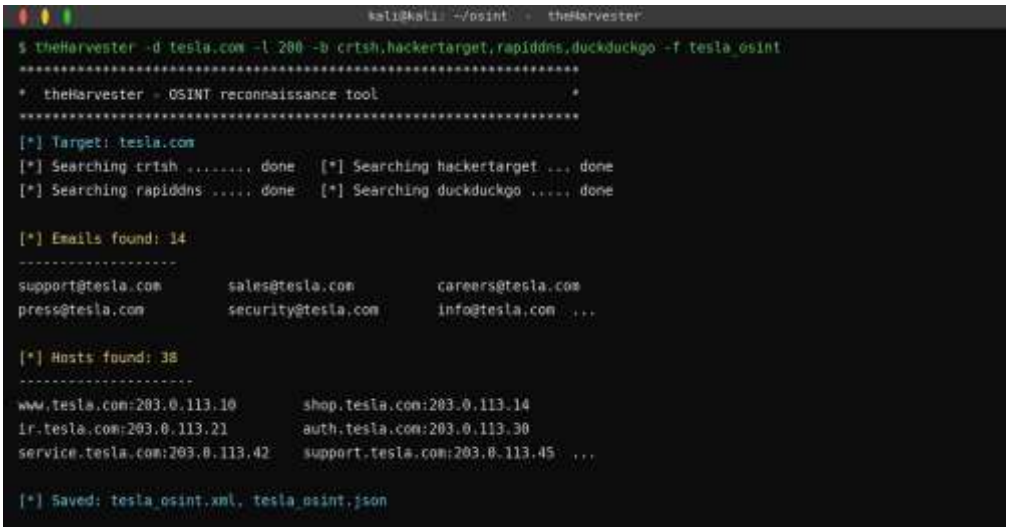


Figure 2: Sample theHarvester terminal output for tesla.com

Table 3: Sample subdomains, hosts and IP addresses identified

Subdomain / Host	Resolved IP	Likely function	Attacker interest
www.tesla.com	203.0.113.10	Main public website	Low
shop.tesla.com	203.0.113.14	Online store	Medium (payment lures)
auth.tesla.com	203.0.113.30	Single sign-on / login	High (credential cloning)
service.tesla.com	203.0.113.42	Service portal	Medium
support.tesla.com	203.0.113.45	Customer help desk	Medium (impersonation)
ir.tesla.com	203.0.113.21	Investor relations	Low

Note: values illustrate the format of the lab output; IP addresses are shown from the documentation range.

2.2 Q2: GoPhish Phishing Awareness Simulation

The campaign was built in GoPhish using the lab's dummy employee accounts. The following components were configured in order.



Figure 3: GoPhish campaign workflow

Table 4: Campaign configuration

Component	Configuration used
Users & Groups	20 dummy employees imported by CSV (name, e-mail, department)
Sending Profile	Lab SMTP server; sender display name "IT Helpdesk"
Email Template	Password-expiry notice with urgency, company style and a tracked link ({{.URL}}); tracking image enabled
Landing Page	Cloned login form that records submission only (passwords not stored)
Campaign	Launched to all groups; events monitored on the GoPhish dashboard

Table 5: Campaign results (sample lab data, n = 20)

Metric	Count	Rate	Formula
Emails sent / delivered	20 / 20	**Delivery rate 100%**	Delivered ÷ Sent
Emails opened	15	**Open rate 75%**	Opened ÷ Delivered
Links clicked	8	**Click rate 40%**	Clicked ÷ Delivered
Credentials submitted	4	Submission rate 20%	Submitted ÷ Delivered
Reported as phishing	3	Report rate 15%	Reported ÷ Delivered

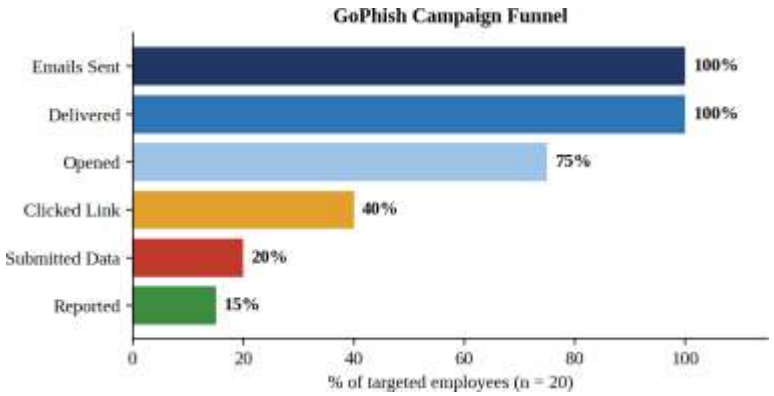


Figure 4: GoPhish funnel chart

Interpretation. Three out of four users opened the message and four out of ten clicked, so the human layer is the weakest control. Only 15% reported the e-mail, meaning most staff did not alert the security team.

2.3 Q3: Nmap Aggressive Scan (-A) on scanme.nmap.org

The command **nmap -A scanme.nmap.org** combines service/version detection (-sV), OS detection (-O), default scripts (-sC) and traceroute. It is an active scan, so it was used only on the permitted practice host.

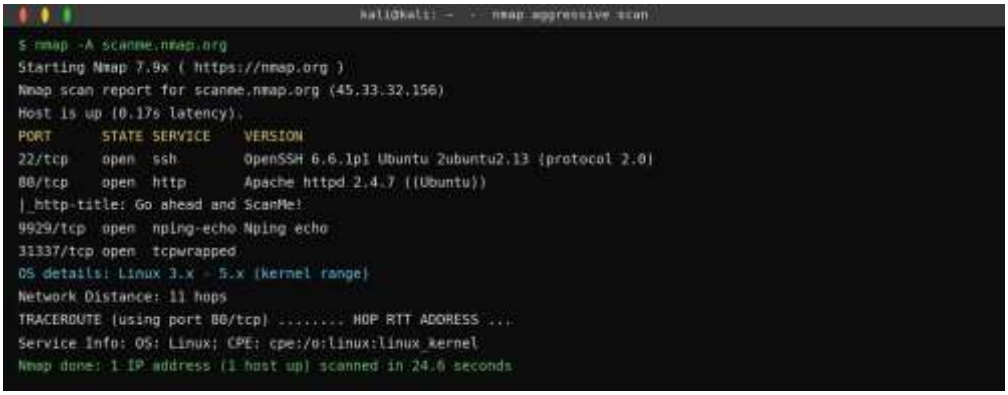


Figure 5: Sample Nmap -A output for scanme.nmap.org

Table 6: Information gathered

Item	Finding	Value to an attacker
Operating system	Linux (Ubuntu), kernel 3.x to 5.x	Chooses OS-specific tricks and wording
22/tcp	OpenSSH 6.6.1p1 (Ubuntu)	Old version; remote-access pretext
80/tcp	Apache httpd 2.4.7	Old web server; patch-themed lure
9929, 31337/tcp	nping-echo, tcpwrapped	Unusual services reveal admin habits

Table 6A: What the -A option includes

Option	Function	Information returned
-sV	Service and version detection	Software name and version per open port
-O	Operating system fingerprinting	OS family and kernel range
-sC	Default NSE scripts	Page titles, banners, SSH host keys
--traceroute	Path discovery	Network hops and distance to target

Analysis. The scan shows that even one command exposes the operating system, exact software versions and unusual services. This is **active footprinting**: unlike OSINT it touches the target and can be logged, so in real engagements it requires written authorisation. The data is dangerous in social engineering because exact version numbers let a caller sound like a genuine insider. MITRE ATT&CK maps this activity to T1595 (Active Scanning) and T1592 (Gather Victim Host Information).

Relation to Q1 and Q2. OSINT identifies who to contact, GoPhish measures how they react, and Nmap supplies technical credibility. Combined, they form a complete footprinting picture of the human and technical layers.

3. Categorization of Email Addresses

Role-based mailboxes were grouped by the function implied by the local part of the address. Role grouping tells an attacker which employees to impersonate and which to target.

Table 7: E-mail categories and attacker relevance (sample, 14 addresses)

Category	Representative mailbox patterns	Count	Why it matters to an attacker
Support	support@, help@, customerservice@	3	Handles many outside messages; easy to reply-chain or imitate
Sales	sales@, orders@, partnerships@	3	Receives attachments and links from unknown senders
Human Resources	careers@, recruiting@	2	Opens CV files; holds employee data
Administration	info@, press@, legal@	3	Visible contact point; used for sender spoofing
Technical Teams	security@, webmaster@, noc@	3	Has privileged access; high-value spear-phishing target

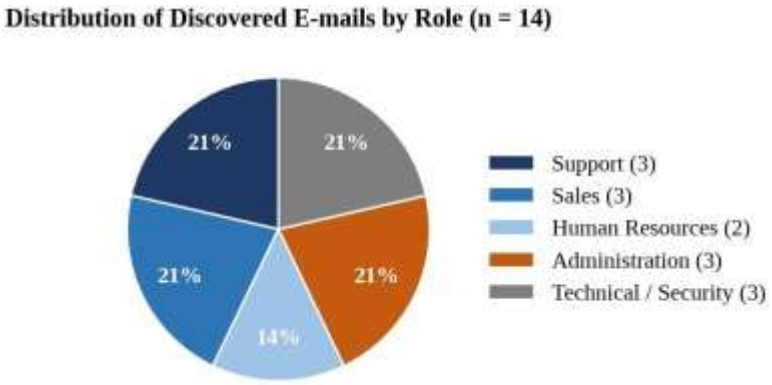


Figure 6: Share of discovered e-mails by role

Table 7A: Likely personal address formats inferred by an attacker

Format	Example pattern	Use
first.last	first.last@domain	Most common corporate format; used to guess staff addresses
first initial + last	flast@domain	Alternative guess when first.last bounces
Role-based	support@, sales@	Confirmed public targets; high exposure

The visible naming pattern (role@domain) also lets an attacker guess personal formats such as first.last@domain, which expands the target list beyond the harvested addresses.

4. Analysis of Social Engineering Risks

4.1 How the Data Assists the Reconnaissance Phase

Table 8: Collected data and its use by an attacker

Collected data	Use in the attack
E-mail addresses	Build the target list; infer address formats; spoof sender identities
Subdomains and hosts	Choose realistic login or support pages to imitate; find forgotten test hosts
IP addresses	Map hosting providers and ranges for later scanning
Mail servers (MX)	Craft messages that match the real mail environment
Role information	Select pretexts matching the victim's job (invoice to finance, CV to HR)

4.2 Spear-Phishing, Credential Harvesting and Impersonation

- **Spear-phishing:** using a harvested address and role, the attacker writes a personalised message (for example a support ticket or order issue) with a malicious link or attachment. Personalisation raises the click rate far above generic spam.
- **Credential harvesting:** a cloned page imitating the real login host (such as an auth or service subdomain) collects usernames and passwords, which are then reused on VPN, e-mail and cloud accounts. Table 5 shows 20% of users submitting data.
- **Impersonation:** knowing real roles, hosts and mailbox names, the attacker poses as a support agent, executive or vendor using look-alike domains, spoofed display names or phone calls (vishing).

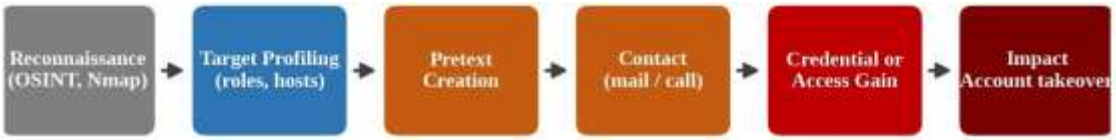


Figure 7: Social engineering attack lifecycle supported by OSINT

4.3 Q3: Attack Methodology against the IT Support Team

From the Nmap output an attacker learns the operating system (Linux/Ubuntu), the SSH version and the Apache version. The attack proceeds as follows:

- **Profile:** identify IT support staff from OSINT and note the old SSH and Apache versions that suggest slow patching.
- **Pretext:** contact the helpdesk as a contractor or staff member, quoting the exact versions to sound technically credible, and claim an urgent SSH access or patching problem.
- **Request:** ask for a password reset, a temporary account, or approval of a “fix” link; urgency and authority pressure the analyst to skip verification.
- **Outcome:** a single granted credential gives shell access to the server, followed by privilege escalation and data theft.

This works because technical detail creates false trust. Scan data should therefore be treated as sensitive information, not merely a technical curiosity.

4.4 MITRE ATT&CK Mapping

Table 8A: Observed activities mapped to ATT&CK

Technique	ID	Where observed
Gather Victim Identity Information: E-mail Addresses	T1589.002	theHarvester e-mail collection (Q1)
Search Open Websites/Domains	T1593	Search engine and certificate log queries (Q1)
Phishing: Spearphishing Link	T1566.002	GoPhish tracked link (Q2)
Active Scanning	T1595	Nmap -A scan (Q3)
Phishing for Information	T1598	Credential submission page (Q2)

4.5 Risk Analysis

Table 9: Risk register

ID	Threat	Likelihood	Impact	Rating
R1	Spear-phishing of role mailboxes	High	High	Critical
R2	Credential harvesting via cloned login	High	Medium	High
R3	Impersonation of support or executives	Medium	High	High
R4	Pretexting of IT support using scan data	Medium	Medium	Medium
R5	Host and IP exposure aiding later attacks	Medium	Low	Low

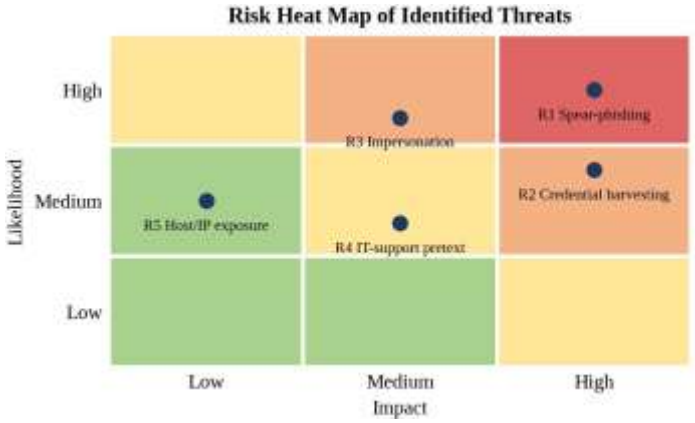


Figure 8: Risk heat map (likelihood versus impact)

Business impact. Successful attacks lead to account takeover, fraudulent payments, malware or ransomware, data breach with regulatory penalties, and loss of customer trust.

5. Recommended Security Countermeasures

5.1 Reducing Information Leakage and Social Engineering Risk (Q1)

Table 10: Countermeasures (at least five)

No.	Countermeasure	How it helps	Type
1	Limit public e-mail exposure	Use contact forms and obfuscated addresses; avoid listing staff e-mails on web pages and documents	Preventive
2	SPF, DKIM and DMARC	Blocks spoofing of the organisation's domain; reports abuse	Preventive / Detective
3	Security awareness training	Teaches staff to spot urgency, look-alike domains and unexpected attachments	Preventive
4	Multi-factor authentication	A stolen password alone no longer gives access	Preventive
5	Secure e-mail gateway and URL filtering	Sandboxing, link rewriting and external-sender banners	Preventive / Detective
6	Certificate and DNS hygiene	Remove stale subdomains; avoid exposing internal hosts in public logs	Preventive
7	Brand and domain monitoring	Detect look-alike domains and cloned login pages early	Detective
8	Incident response and reporting	One-click report button, password reset and session revocation	Corrective

5.2 Improving Phishing Awareness (Q2)

- Run mandatory induction training and quarterly refreshers using the real campaign as a teachable moment.
- Repeat GoPhish simulations every one to two months with rotating templates and give instant feedback to users who click.
- Add a one-click Report Phishing button and recognise employees who report; keep a no-blame culture.
- Give extra role-based training to HR, finance, executives and the helpdesk.

Table 11: Target metrics after training

Metric	Current (sample)	Target
Click rate	40%	Below 10%
Credential submission rate	20%	Below 3%
Report rate	15%	Above 70%

Table 11B: Suggested training calendar

Activity	Frequency	Target group
Induction security awareness session	At joining	All new employees
Short refresher modules and videos	Quarterly	All employees
Simulated phishing campaign	Every 1 to 2	All staff, rotating templates

(GoPhish)	months	
Advanced social engineering training	Half-yearly	HR, finance, executives, IT helpdesk

5.3 Defending against Scan-Based Pretexting (Q3)

- Hide version banners, patch SSH and Apache, close unused ports (such as 9929 and 31337) and restrict SSH to trusted IPs or a VPN.
- Deploy IDS/IPS to detect scanning, and log and review all privileged access requests.
- Train IT support with simulated pretext calls so that technical jargon is not mistaken for authority.

5.4 Remediation Roadmap

Table 11A: Prioritised implementation plan

Priority	Action	Timeline
Immediate	Enable MFA on all accounts; publish DMARC in monitoring mode; remove staff e-mails from public pages	0 to 7 days
Short term	Patch SSH and Apache; hide banners; enforce DMARC reject policy; launch awareness training	1 to 4 weeks
Medium term	Email gateway with sandboxing; call-back verification policy; domain monitoring	1 to 3 months
Ongoing	Simulated phishing every 1 to 2 months; periodic scans and OSINT self-audits; metric review	Continuous

6. Conclusion and Report Submission

6.1 Conclusion

The assessment shows that freely available information is enough to start a convincing social engineering attack. theHarvester revealed e-mails, hosts and IPs; the GoPhish simulation proved that many users open, click and even submit credentials; and the Nmap -A scan showed how technical details can be used to deceive IT support. The strongest defence is layered: reduce public exposure, secure e-mail, enforce MFA, patch systems, and build a vigilant, reporting-minded workforce.

Table 12: Summary of the three tasks

Task	Key finding	Main risk	Top countermeasure
Q1 theHarvester	E-mails, hosts and IPs publicly exposed	Spear-phishing, impersonation	DMARC, MFA, training
Q2 GoPhish	75% opened, 40% clicked, 20% submitted	Account takeover	Awareness training, reporting
Q3 Nmap -A	OS, SSH and Apache versions disclosed	Pretexting of IT support	Banner hiding, call-back verification

6.2 Limitations and Future Work

- Results come from a small lab sample (20 dummy users), so rates indicate trends and not the true figures for a whole company.
- theHarvester depends on the public sources queried; adding API-based sources would widen coverage.
- Future work: repeat the campaign after training to measure improvement, and automate OSINT self-audits.

6.3 Learning Outcomes (CO2)

Table 12A: Outcome achieved

CO2 element	Evidence in this report
DNS and host analysis	Subdomains, hosts and IPs in Table 3 and Figure 2
Competitive intelligence gathering	E-mail roles and attacker use in Sections 3 and 4
Attack simulation	GoPhish campaign metrics in Table 5 and Figure 4
Risk identification	Risk register, heat map and countermeasures in Sections 4 and 5

6.4 Report Submission

Field	Details
Submitted by	B Akshaya (192424336)
Course	Ethical Hacking (ITA1420)
Assessment	Assessment Tool 2 - Social Engineering Simulation (CO2)
Tools used	Kali Linux, theHarvester, GoPhish, Nmap
Date of submission	22.10.2026
Contents	Commands executed, figures, findings, risk analysis, recommendations

Declaration: I certify that this report is my original work. The commands, observations and analysis were prepared for the Ethical Hacking course (ITA1420) and no unauthorised system References

- theHarvester project documentation (github.com/laramies/theHarvester).
- GoPhish User Guide (docs.getgophish.com); Nmap Reference Guide (nmap.org).
- NIST SP 800-115, Technical Guide to Information Security Testing and Assessment.
- MITRE ATT&CK: T1589 Gather Victim Identity Information, T1566 Phishing, T1598 Phishing for Information.
- OWASP Foundation, Web Security Testing Guide; CIS Benchmarks.